

DigitalBase セキュリティチェックシート

Security Checklist

最終更新日: 2026年4月

本チェックシートは、DigitalBase の導入にあたり、お客様のIT部門・セキュリティ部門での審査にご利用いただくためのものです。

1. 事業者情報

No.	項目	回答
1.1	会社名	デジタルベース株式会社
1.2	設立	2023年4月
1.3	資本金	2,500,000円
1.4	代表者	今井 康之
1.5	所在地	東京都港区北青山1-3-3 三橋ビル 3階
1.6	事業内容	各種ソフトウェアに関する開発、保守、販売、コンサルティング業務
1.7	ウェブサイト	https://digital-base.co.jp
1.8	プロダクトサイト	https://digitalbase.jp

2. 製品概要

No.	項目	回答
2.1	製品名	DigitalBase
2.2	製品分類	セルフホスト型AIデータ連携基盤
2.3	動作環境	お客様のサーバー / PC 上
2.4	提供形態	PyInstallerバイナリ / Docker Compose
2.5	対応OS	macOS / Linux / Windows

3. データ管理

No.	項目	回答
3.1	データの保存場所	お客様環境内のみ — PostgreSQL データベース
3.2	クラウドへのデータ送信	デフォルトなし — 完全オフライン動作可能。クラウドLLM利用時のみプロンプトが送信される（管理者が明示的に有効化した場合のみ）
3.3	テレメトリ / 利用統計の送信	なし
3.4	ライセンス認証の通信	なし — Hardware UUIDベースのオフライン認証
3.5	データの暗号化（保存時）	PostgreSQLの暗号化機能（TDE等）に依存。お客様環境で設定可能
3.6	データの暗号化（通信時）	Nginxリバースプロキシによる HTTPS 対応可能
3.7	データバックアップ	<code>pg_dump</code> による標準的なPostgreSQLバックアップ。お客様にて運用
3.8	データ消去	アンインストールスクリプトにてアプリケーションデータを削除。DBは <code>DROP DATABASE</code> で完全消去
3.9	データの国外移転	なし（お客様環境内で完結）。クラウドLLM利用時はプロバイダーの規約に準拠
3.10	第三者へのデータ提供	なし

3A. クラウドLLM連携のデータ管理

No.	項目	回答
3A.1	クラウドLLM利用時の送信データ	プロンプト（ユーザーの質問文 + RAGコンテキスト）のみ。DB全体やファイルは送信されない
3A.2	対応プロバイダー	OpenAI（GPT系）、Anthropic（Claude系）、Google（Gemini系）
3A.3	APIキー管理	<code>.env</code> ファイルで管理。アプリケーション内にはハードコードしない

No.	項目	回答
3A.4	デフォルト状態	無効 — APIキー未設定時はクラウドLLMは一切利用されない
3A.5	切替の制御	管理者が <code>.env</code> でAPIキーを設定 → ユーザーがモデルヘッダーで選択
3A.6	ログ	クラウドLLMへのリクエストはアプリケーションログに記録（プロバイダー名、モデル名、トークン数）

3B. Web検索のデータ管理

No.	項目	回答
3B.1	Web検索の送信データ	検索クエリ（ユーザーの質問から生成）のみ
3B.2	検索プロバイダー	DuckDuckGo（デフォルト） / SearXNG（セルフホスト）
3B.3	デフォルト状態	無効 — <code>WEB_SEARCH_ENABLED=false</code> がデフォルト
3B.4	プライバシー保護	SearXNG（セルフホスト）利用時は検索クエリも社外に出ない
3B.5	結果のキャッシュ	なし（毎回リアルタイム検索）

3C. Tool Calling / MCPのデータ管理

No.	項目	回答
3C.1	Tool Callingのデフォルト	無効 — ユーザーがuser-settingsで明示的に有効化
3C.2	MCP接続先の管理	ユーザー設定で管理。管理者が許可したサーバーのみ接続可能
3C.3	ツール実行のログ	アプリケーションログにツール名、引数、結果概要を記録
3C.4	ファイル読み取りの制限	許可ディレクトリのみアクセス可能（user-settingsで設定）
3C.5	SQLクエリの制限	SELECT文のみ実行可能（INSERT/UPDATE/DELETE拒否）

3D. パイプラインのデータ管理

No.	項目	回答
3D.1		お客様環境内のPostgreSQLに保存

No.	項目	回答
	パイプライン実行 データ	
3D.2	外部API連携	REST API / Webhook / SMTP はユーザーが設定した宛先にのみ送信
3D.3	コード実行	サンドボックス環境（危険なビルトイン・モジュール制限、タイムアウト制御）
3D.4	ループ保護	max_iterations制限（デフォルト1000）で無限ループ防止
3D.5	リトライ制御	指数バックオフ（retry_wait_ms × 2^attempt）で過剰リトライ防止

4. 認証・アクセス制御

No.	項目	回答
4.1	認証方式	ローカル（ID/パスワード） / LDAP / OIDC から選択
4.2	LDAP / Active Directory 対応	対応 — AD / OpenLDAP。初回ログイン時にユーザー自動作成。属性取得（employeeID, department等）
4.3	OIDC / Azure AD 対応	対応 — Microsoft Entra ID。初回サインイン時にユーザー自動作成
4.4	パスワードハッシュ	bcrypt（12ラウンド）
4.5	パスワードポリシー	お客様のLDAP/AD側のポリシーに準拠（ローカル認証時はアプリ側で管理）
4.6	ロールベースアクセス制御	あり — ADMIN / SUPER / USER の3段階
4.7	セッション管理	JWT (Bearer Token) （有効期間365日、 <code>.env</code> で変更可能）
4.8	管理者アカウントの保護	最後のADMINは削除・降格不可
4.9	デフォルトパスワード	初期: admin@local / admin123 — 初回ログイン後に変更必須
4.10	ユーザー数制限	ライセンスに基づく上限あり
4.11	AD/OIDC環境の管理者アクセス	admin@local は常にローカル認証可能
4.12	同時ログイン制御	JWT方式のため複数端末からの同時ログイン可能

No.	項目	回答
4.13	アカウントロックアウト	LDAP/AD側のポリシーに準拠（ローカル認証時は現在未実装）
4.14	タグベースアクセス制御	Bot・パイプライン・ワークフロー・接続情報の共有範囲をタグで管理

5. ネットワーク

No.	項目	回答
5.1	必要なポート	API+Web: 8000, PostgreSQL: 5432, Ollama: 11434（vLLM: 8080, 8081）
5.2	外部への通信	デフォルト不要 。クラウドLLM / Web検索 / MCP 有効化時のみ必要
5.3	HTTPS対応	Nginxリバースプロキシにて対応可能
5.4	ファイアウォール設定	ufw によるIP制限・ポート制御をサポート
5.5	LAN内アクセス	0.0.0.0 バインドでLAN内共有可能（127.0.0.1 でローカル限定）
5.6	VPN対応	お客様環境のVPN設定に依存（本製品側の制約なし）
5.7	WAF	お客様環境にて別途導入可能
5.8	Webhook送信先	パイプライン / 承認フロー / ヘルプデスクからの通知。送信先はユーザーが設定
5.9	SMTP送信	パイプラインからのメール通知。SMTP設定はパイプラインステップ内で指定

6. アプリケーションセキュリティ

No.	項目	回答
6.1	SQLインジェクション対策	SQLAlchemy によるパラメータ化クエリ。パイプラインSQLオペレーターも <code>:param</code> パラメータ化対応
6.2	XSS対策	React の自動エスケープ処理
6.3	CSRF対策	JWT認証 + FastAPI CORS
6.4	API認証	ライセンス検証 + セッション認証の二重チェック

No.	項目	回答
6.5	ファイルアップロード制限	最大100MB（音声ファイル）。パイプライン用アップロードは~/uploads/に保存
6.6	API ドキュメント保護	本番ビルドではSwagger UI / ReDocは無効化
6.7	入力値バリデーション	FastAPI の Pydantic モデルによる型検証 + フロントエンド側バリデーション
6.8	エラーハンドリング	内部エラーの詳細はクライアントに返さない（500エラー時はジェネリックメッセージ）
6.9	依存パッケージの脆弱性管理	pip audit による定期チェック
6.10	コード実行サンドボックス	パイプラインのコード変換は危険なビルトイン（exec, eval, open, import ）を除去、許可モジュールのみ利用可
6.11	ファイルアクセス制御	Tool Callingのファイル読み取りはホームディレクトリ内 or 指定ディレクトリのみ
6.12	Webhookセキュリティ	HMAC署名（sha256）による送信元検証

7. 人的セキュリティ

No.	項目	回答
7.1	開発者のセキュリティ知見	代表がインテルでのAI・セキュリティ関連業務経験あり
7.2	守秘義務契約	開発関係者とNDAを締結
7.3	ソースコードアクセス管理	プライベートリポジトリで管理。アクセス権限は最小限に制限

8. 物理セキュリティ

No.	項目	回答
8.1	データセンター	該当なし — セルフホストソフトウェアのため、お客様環境に依存
8.2	入退室管理	該当なし — 同上
8.3	機器の廃棄	該当なし — お客様側で管理

9. 監査・ログ

No.	項目	回答
9.1	チャット履歴管理	ADMINが全ユーザーのチャット履歴を閲覧可能
9.2	アプリケーションログ	~/local/db/logs/ へ出力
9.3	パイプライン実行履歴	実行日時、ステータス、ステップ結果、エラー詳細をDB保存
9.4	最終ログイン記録	ユーザーごとに lastLoginAt を記録
9.5	ログの保存期間	お客様環境のディスク容量に依存。ログローテーションはお客様にて設定可能
9.6	ログの改ざん防止	ファイルシステムの権限設定に依存（お客様環境）
9.7	外部SIEM連携	ログファイルをお客様のSIEMで取り込み可能（標準テキスト形式）

10. インシデント対応

No.	項目	回答
10.1	脆弱性発見時の対応	セキュリティパッチを作成し、ライセンス登録メール宛に緊急通知
10.2	インシデント連絡先	info@digital-base.co.jp
10.3	初動対応時間	P1（緊急）：4時間以内に調査開始
10.4	脆弱性報告の受付	メールにて受付。報告者への対応状況通知あり
10.5	過去の重大インシデント	該当なし（2025年リリース以降）

11. 事業継続

No.	項目	回答
11.1	製品のBCP	ソースコードはリモートリポジトリで冗長管理。開発環境の復旧は即時可能
11.2	データの冗長化	お客様環境でのPostgreSQLレプリケーション設定に依存

No.	項目	回答
11.3	EOL（サポート終了）ポリシー	エンドユーザー: 3ヶ月前に通知 / パートナー: 12ヶ月前に通知
11.4	ソースコードエスクロー	個別協議にて対応可能

12. ソフトウェア構成

No.	項目	回答
12.1	フロントエンド	Vite + React 19 + shadcn/ui + ReactFlow
12.2	バックエンド	FastAPI (Python) + uvicorn
12.3	データベース	PostgreSQL 17 + pgvector
12.4	ORM	SQLAlchemy 2.0+
12.5	LLMエンジン	Ollama（標準） / vLLM（高性能） / クラウドLLM（オプション）
12.6	LLM通信方式	httpxによるHTTPリクエスト（OpenAI SDK不使用）
12.7	認証ライブラリ	JWT + bcrypt + ldap3（LDAP） + httpx（OIDC）
12.8	パイプライン	19オペレーター + APScheduler + ReactFlow
12.9	バイナリ配布	PyInstaller + Cython
12.10	OSS ライセンス	使用OSSは各ライセンス条件に準拠（MIT, Apache 2.0, BSD等）

13. ライフサイクル管理

No.	項目	回答
13.1	アップデート方法	インストールコマンドの再実行（データ保持）。 <code>db start</code> で起動
13.2	セキュリティパッチ提供	脆弱性発見時に随時提供。ライセンス登録メール宛に通知
13.3	アップデート通知方法	ライセンス発行時のメールアドレス宛にメール送付（SendGrid）
13.4	データ移行	<code>pg_dump</code> / <code>pg_restore</code> による標準手順
13.5		

No.	項目	回答
	依存ソフトウェアのEOL 対応	Python / PostgreSQL 等のLTS版を使用。EOL前に対応版をリリース

14. コンプライアンス・認証

No.	項目	回答
14.1	個人情報保護法 対応	プライバシーポリシーにて取扱いを明記。お客様環境内にデータが留まるため、当社がデータ処理者となることはない
14.2	データ所在地	お客様環境内（国内設置であれば国内）。クラウドLLM利用時はプロバイダーの規約に準拠
14.3	ISMS（ISO 27001）	未取得（取得検討中）
14.4	プライバシー マーク	未取得
14.5	SOC 2	未取得
14.6	ISMAP	該当なし（セルフホストソフトウェアのため対象外）
14.7	SECURITY ACTION	宣誓済み（一つ星）
14.8	輸出管理	個別対応
14.9	GDPR	お客様環境内にデータが留まるため、当社側でのGDPR対応義務は発生しない。クラウドLLM利用時はプロバイダーの規約に準拠
14.10	第三者監査	未実施（個別協議にて対応可能）

15. サポート体制

No.	項目	回答
15.1	サポート窓口	メール: info@digital-base.co.jp
15.2	受付時間	平日 10:00-18:00（スタンダード） / 9:00-21:00（エンタープライズ）
15.3	初回応答時間	2営業日以内（スタンダード） / 4時間以内（エンタープライズ）
15.4	障害時の連絡方法	メール / 電話（エンタープライズ）

No.	項目	回答
15.5	SLA	別紙「サービスレベル合意書」にて定義

お問い合わせ

セキュリティに関する詳細な質問は、個別にお問い合わせください。

デジタルベース株式会社 - メール: info@digital-base.co.jp - ウェブサイト: <https://digital-base.co.jp> - プロダクトサイト: <https://digitalbase.jp>

Copyright (c) 2026 デジタルベース株式会社 All rights reserved.